

CURLING

Security Assessment Report

Retired Hack The Box Linux Machine

Assessment	Details
Assessment date	November 5, 2026
Assessment type	Black-box penetration test in a controlled training lab
Target	Curling — retired Hack The Box Linux machine
Target address	10.129.95.142 (at the time of assessment)
Prepared for	Cybersecurity portfolio

PORTFOLIO COPY • CONTROLLED LAB ENVIRONMENT • CREDENTIALS AND FLAGS REDACTED

1 Executive Summary

The assessment achieved full compromise of the retired Hack The Box machine Curling. The attack chain began with a publicly accessible file reference discovered in the Joomla article source. The referenced `/secret.txt` resource returned a Base64-encoded credential. Decoding the value enabled access to the Joomla administrator interface.

From the authenticated Joomla administrator session, the Protostar template editor was used to place a PHP probe in the template directory. The probe executed on the web server as www-data (UID 33). Host enumeration located a nested compressed backup in Floris' home directory. Reconstructing and extracting the archive recovered a credential that enabled SSH access as floris.

Local enumeration identified a root-run cron job that invoked `curl -K` against an input file writable by the floris group. By replacing the curl configuration, the scheduled task was made to write an attacker-controlled sudoers file. The resulting sudo rule enabled a root shell. Both user and root flags were obtained; values are redacted.

Primary findings: publicly exposed credential material, authenticated PHP execution through Joomla template administration, disclosure of an SSH credential in a nested backup archive, and root privilege escalation through an unsafe curl configuration in a privileged cron job.

2 Assessment Context and Scope

Item	Details
Target	Curling — retired Hack The Box Linux machine
Target address	10.129.95.142 (address assigned after machine restart)
In-scope services	TCP/22 SSH; TCP/80 HTTP
Approach	External reconnaissance, web application inspection, credential recovery, authenticated PHP execution, local enumeration, privilege escalation
Environment	Controlled Hack The Box training environment
Limitations	No remediation or post-remediation retest performed

HTB lab addresses can change when a machine is restarted or a new instance is assigned.

3 Methodology and Tools

The workflow progressed from Nmap and Nikto reconnaissance to manual source inspection with Burp Suite, credential decoding, Joomla administrator access, template-based PHP execution, host and file enumeration, archive reconstruction, SSH authentication, cron/process inspection, and privilege escalation.

Tools evidenced: Nmap, Nikto, Burp Suite, browser-based Joomla administration, curl, PHP, xxd, bzip2, gzip, tar, SSH, pspy, and standard Linux utilities.

4 Reconnaissance and Vulnerability Identification

4.1 Port and Service Discovery

The post-restart scan against 10.129.95.142 identified two open TCP services: SSH on port 22 and HTTP on port 80. The HTTP service exposed Joomla login and article routes. Earlier service-version enumeration on the same retired machine identified OpenSSH 7.6p1 and Apache 2.4.29; the Joomla system-information page later confirmed the application and supporting software versions.

```
└─ [★]$ nmap --script vuln 10.129.95.142
Starting Nmap 7.95 ( https://nmap.org ) at 2026-11-05 05:08 EST
Nmap scan report for 10.129.95.142
Host is up (0.0074s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=10.129.95.142
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://10.129.95.142:80/
|     Form id: login-form
|     Form action: /index.php
|
|     Path: http://10.129.95.142:80/index.php/2-uncategorised
|     Form id: login-form
|     Form action: /index.php
|
|     Path: http://10.129.95.142:80/index.php/2-uncategorised/1-first-post-of-cu
rling2018
|     Form id: login-form
```

Figure 1. Nmap vulnerability-script scan against 10.129.95.142 identifies SSH/22 and HTTP/80 and enumerates Joomla form endpoints.

4.2 Joomla Fingerprinting and HTTP Enumeration

Nmap HTTP enumeration identified the Joomla 3.8.8 manifest and language files, the administrator area, and common application directories. The crawler also observed possible CSRF and DOM-based XSS indicators. These are scanner leads only; the screenshots do not document validation of either issue.

```
|   Found the following indications of potential DOM based XSS:
|
|     Source: window.open(this.href,'win2','status=no,toolbar=no,scrollbars=yes,titlebar=no,menubar=no,resizable=yes,
width=640,height=480,directories=no,location=no')
|_    Pages: http://10.129.95.142:80/, http://10.129.95.142:80/, http://10.129.95.142:80/, http://10.129.95.142:80/in
dex.php/2-uncategorised, http://10.129.95.142:80/index.php/2-uncategorised, http://10.129.95.142:80/index.php/2-uncat
egorised, http://10.129.95.142:80/index.php/2-uncategorised/1-first-post-of-curling2018, http://10.129.95.142:80/inde
x.php/2-uncategorised/2-curling-you-know-its-true, http://10.129.95.142:80/index.php/2-uncategorised/3-what-s-the-obj
ect-of-curling
| http-enum:
|   /administrator/: Possible admin folder
|   /administrator/index.php: Possible admin folder
|   /administrator/manifests/files/joomla.xml: Joomla version 3.8.8
|   /language/en-GB/en-GB.xml: Joomla version 3.8.8
|   /htaccess.txt: Joomla!
|   /README.txt: Interesting, a readme.
|   /bin/: Potentially interesting folder
|   /cache/: Potentially interesting folder
|   /images/: Potentially interesting folder
```

Figure 2. Nmap HTTP enumeration identifies Joomla 3.8.8, the administrator area, and application directories.

The scanner observations helped prioritize the Joomla administrator interface and publicly served application files for manual inspection.

4.3 Web Server Review

Nikto identified Apache/2.4.29 on Ubuntu and reported that the server version appeared outdated relative to the version known to the scanner. It also reported missing recommended HTTP security headers, an administrator login page, and several potentially interesting paths. These observations indicate hardening and patch-management issues; they do not, by themselves, prove remote code execution or another exploitable vulnerability.

```
---------------------------------------------------------------------------
+ Server: Apache/2.4.29 (Ubuntu)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.4.29 appears to be outdated (current is at least 2.4.66).
+ [999979] /images: IP address found in the 'location' header. The IP is "dead:beef::a0de:adff:fef8:e96e". See: https://port
swigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ [999988] /images: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0.
 The value is "dead:beef::a0de:adff:fef8:e96e". See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/
Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/H
TTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/
HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Hea
ders/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/We
b/HTTP/Headers/Strict-Transport-Security
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [999972] /: DEBUG HTTP verb may show server debugging information. See: https://docs.microsoft.com/en-us/visualstudio/debu
gger/how-to-enable-debugging-for-aspnet-applications?view=vs-2017
+ [001587] /bin/: This might be interesting.
+ [001702] /includes/: This might be interesting.
+ [001897] /tmp/: This might be interesting.
+ [003573] /LICENSE.txt: License file found may identify site software.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [006270] /administrator/index.php: Admin login page/section found.
```

Figure 3. Nikto reports an older Apache version, missing recommended security headers, and the Joomla administrator endpoint.

4.4 Application and Platform Information

The Joomla System Information page disclosed Joomla 3.8.8, PHP 7.2.24-0ubuntu0.18.04.8, MySQL 5.7.35-0ubuntu0.18.04.1, and Apache/2.4.29. The operating system/kernel string identified Ubuntu 18.04.5 LTS with kernel 4.15.0-156-generic.

System Information

Setting	Value
PHP Built On	Linux curling 4.15.0-156-generic #163-Ubuntu SMP Thu Aug 19 23:31:58 UTC 2021 x86_64
Database Type	mysql
Database Version	5.7.35-0ubuntu0.18.04.1
Database Collation	utf8_general_ci
Database Connection Collation	utf8mb4_general_ci
PHP Version	7.2.24-0ubuntu0.18.04.8
Web Server	Apache/2.4.29 (Ubuntu)
WebServer to PHP Interface	apache2handler
Joomla! Version	Joomla! 3.8.8 Stable [Amani] 22-May-2018 14:00 GMT
Joomla! Platform Version	Joomla Platform 13.1.0 Stable [Curiosity] 24-Apr-2013 00:00 GMT
User Agent	Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

Figure 4. Joomla System Information exposes the Joomla, PHP, MySQL, Apache, and Linux versions.

The legacy versions were recorded as supporting risk observations. No specific CVE exploit against these components was used in the demonstrated attack chain.

5 Credential Discovery

5.1 Manual Inspection with Burp Suite

The first article page was intercepted and reviewed in Burp Suite. Inspection of the HTML response revealed a comment referencing `secret.txt`. The comment was not presented in the rendered page, so it was not apparent during ordinary browser navigation.

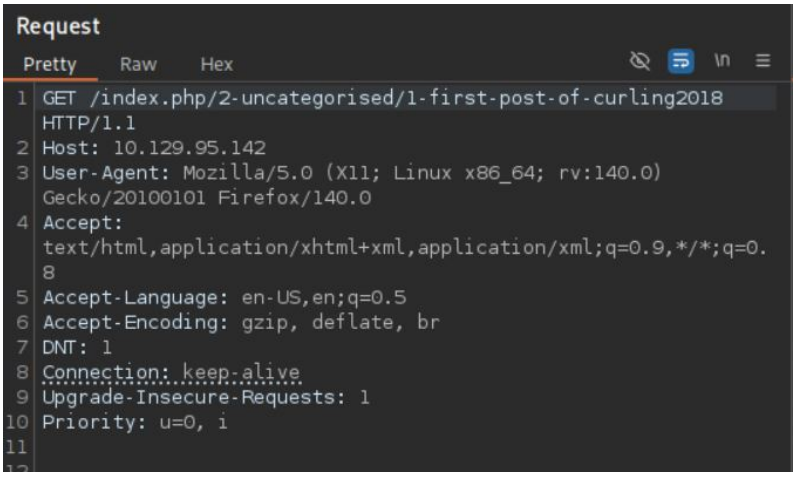


Figure 5. Burp Suite request for the first curling article used during manual response inspection.



Figure 6. Cropped response evidence shows the HTML comment referencing secret.txt; unrelated token material is omitted.

5.2 Public Secret File and Base64 Decoding

Requesting `/secret.txt` returned a short Base64-encoded value with HTTP 200 OK. Base64 is an encoding scheme, not encryption. Decoding the value revealed a credential that was accepted by the Joomla administrator login. The response value and decoded credential are intentionally redacted in this portfolio copy.

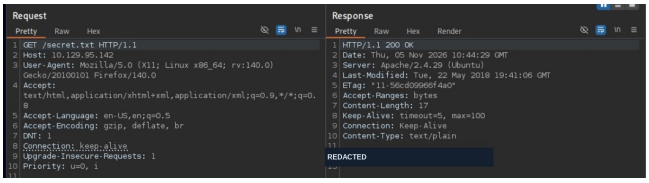


Figure 7. /secret.txt response with the encoded credential redacted.

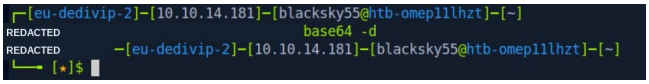


Figure 8. Base64 decoding step with the recovered value redacted.

6 Joomla Administrator Access

The decoded credential enabled authentication to the Joomla administrator interface. The session was confirmed by the administrator control panel and by the site login module displaying the authenticated Super User session. This access was the prerequisite for using Joomla's built-in template management features.

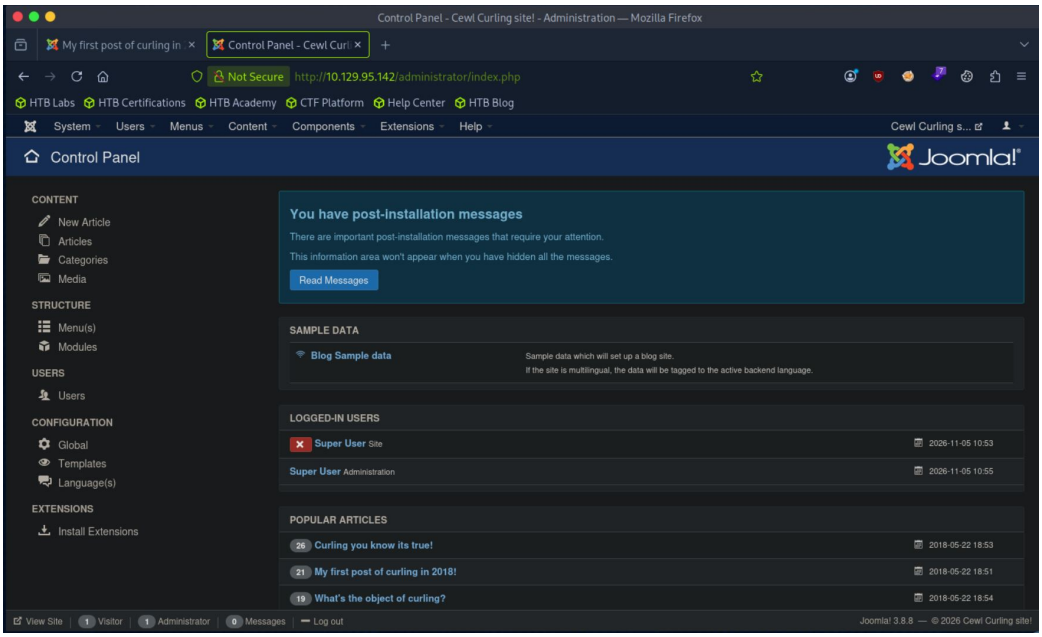


Figure 9. Authenticated Joomla administrator control panel; the logged-in Super User session is visible.

6.1 Template Management

The administrator account had access to the template management area. The site used the Protostar template as the default template for all pages. The administrator interface exposed the template style and its file customisation controls.

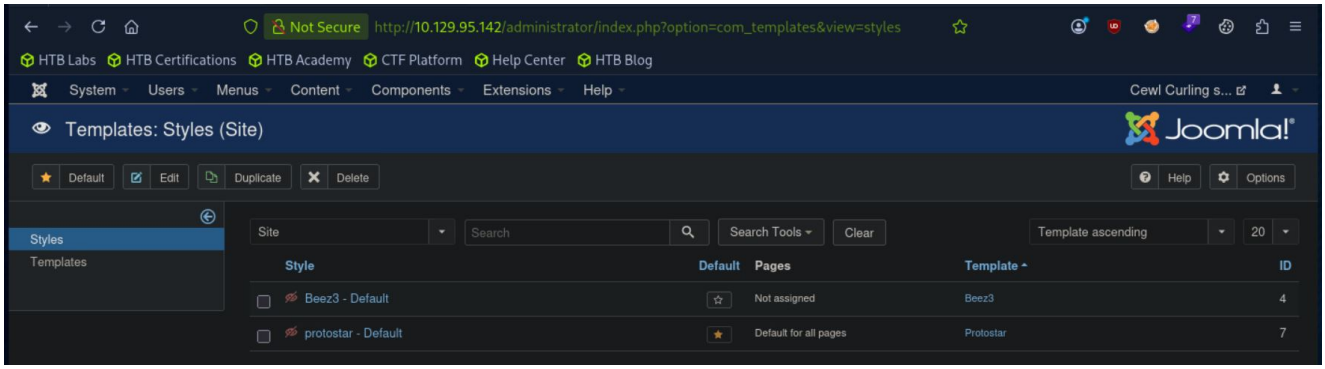


Figure 10. Joomla Template Styles shows Protostar configured as the default site template.

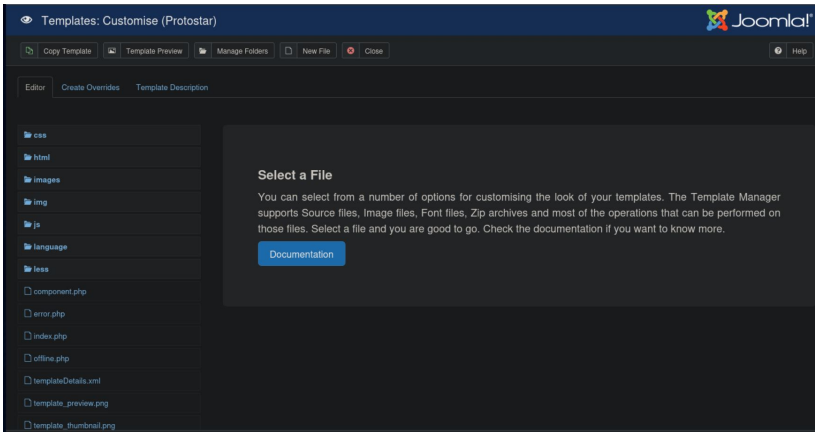


Figure 11. Protostar template customisation interface exposes template files, including PHP source files.

6.2 Authenticated PHP Execution

Using the template editor, a PHP probe file was placed in the Protostar template directory at `/templates/protostar/probe.php`. Requesting this file through the web server returned the expected PHP execution response. This demonstrated server-side PHP execution in the context of the web application.

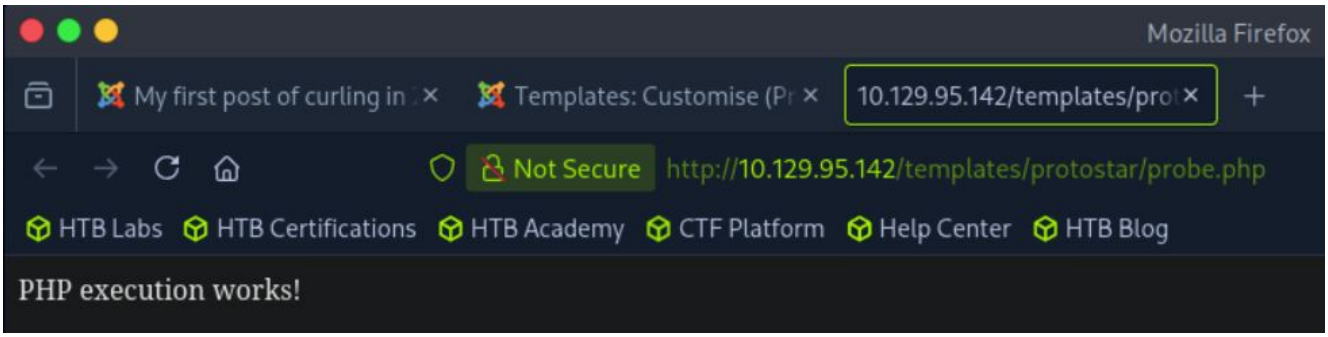


Figure 12. Requesting probe.php under the Protostar template directory returns the PHP execution test string.

The probe then reported the effective account and working directory. The process was running as www-data, UID/GID 33, with its working directory under `/var/www/html/templates/protostar`. This established the initial operating-system foothold.

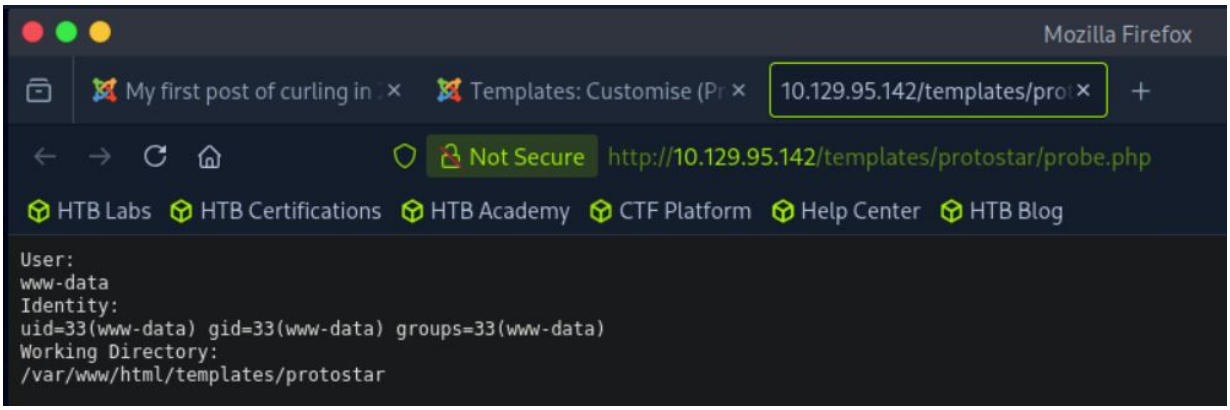


Figure 13. PHP execution runs as www-data (UID/GID 33) in the Protostar template directory.

Impact

A Joomla administrator session with template-editing rights could write executable PHP into a web-accessible template directory. A subsequent HTTP request executed the code under the web server account. This converted application-level administrator access into operating-system command execution as www-data.

7 Initial Host Enumeration as www-data

With the PHP execution context established, filesystem enumeration was performed from the web server process. The root directory listing showed the standard Linux filesystem hierarchy and a `/home` directory. Navigating into `/home/floris` revealed the Floris home directory.

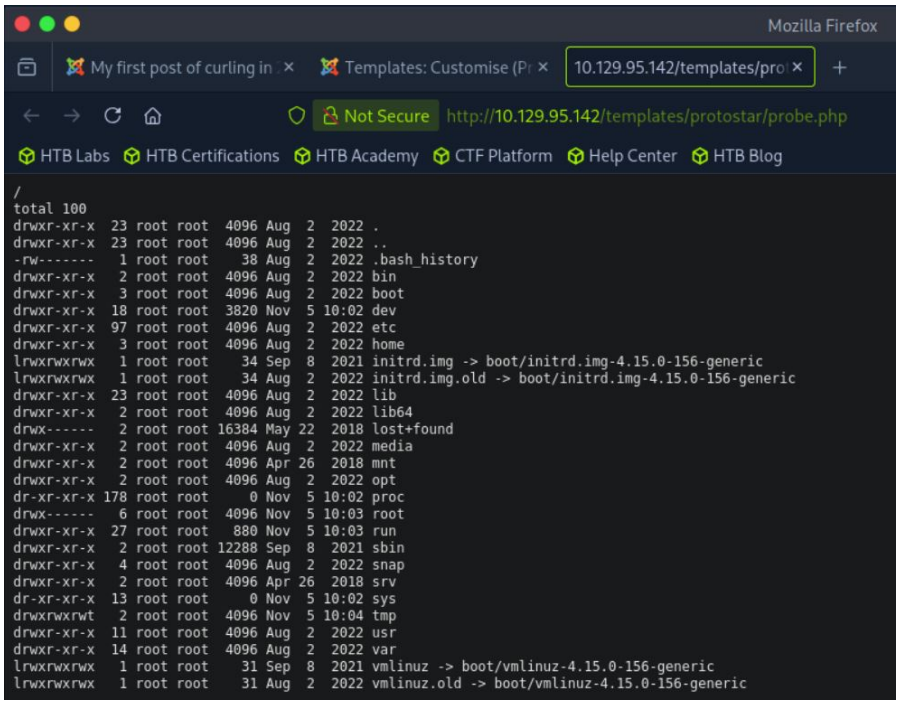


Figure 14. Filesystem listing from the PHP execution context shows the root directory hierarchy.

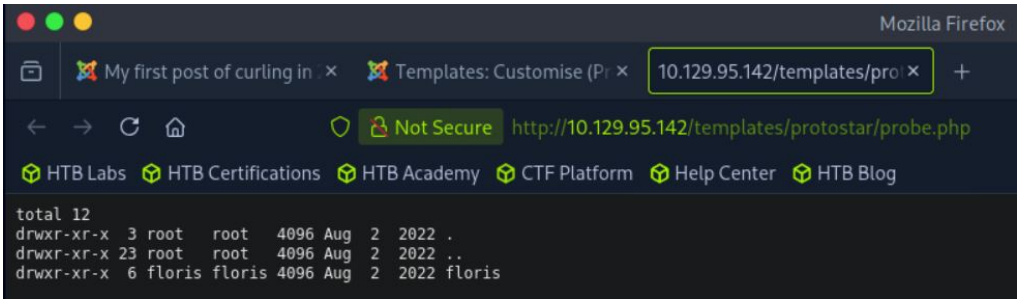


Figure 15. The Floris home directory is discoverable through the PHP execution context.

7.1 Discovery of the Password Backup

The home directory contained a file named `password_backup`. Attempting to read `user.txt` directly returned “Permission denied”, while the backup file could be inspected. The backup content appeared to be binary data represented through a text/hex view.

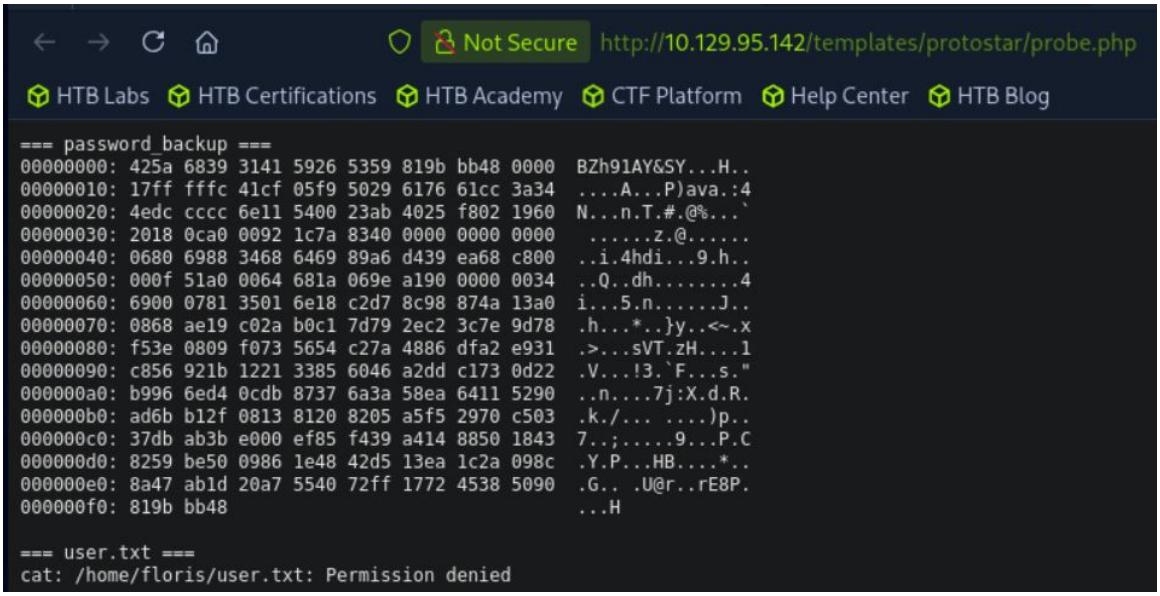


Figure 16. password_backup is present in Floris' home directory; direct access to user.txt is denied to www-data.

7.2 Password Backup Reconstruction

The file did not initially pass the bzip2 integrity check because the visible backup was not in a directly usable binary form. The data was reconstructed with `xxd -r` into a binary file, after which `bzip2 -tv` reported a valid bzip2 stream.

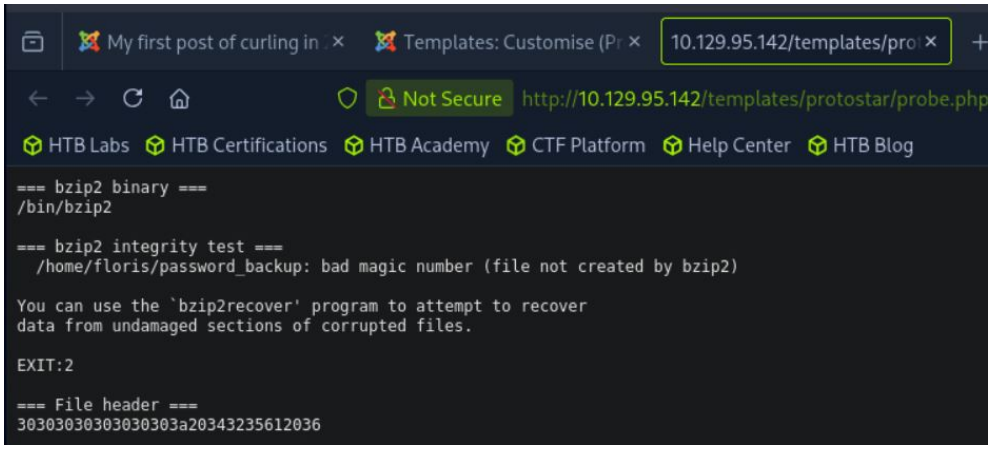


Figure 17. Initial bzip2 check reports a bad magic number and shows the file header requiring reconstruction.

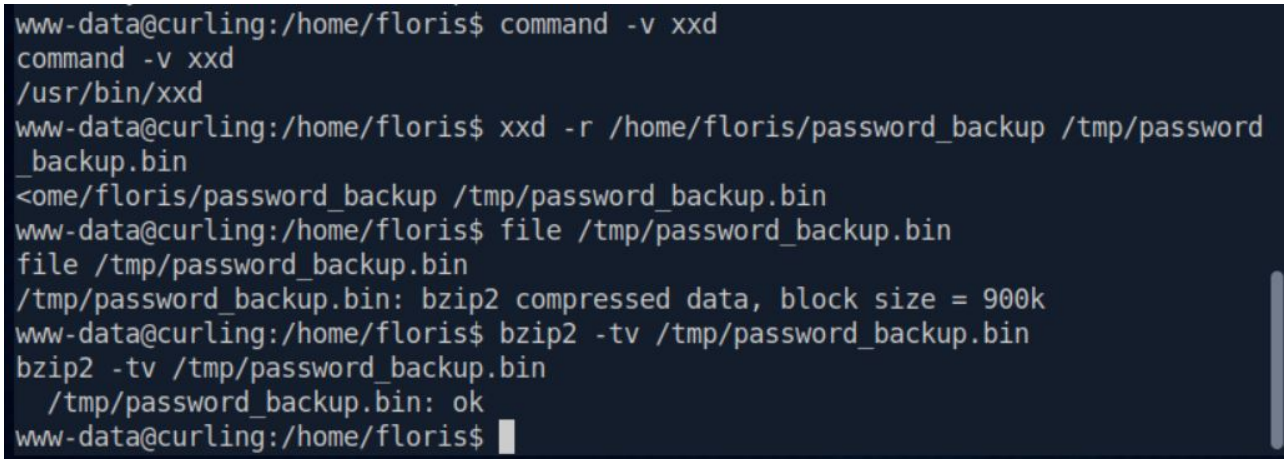


Figure 18. xxd reconstruction produces a valid bzip2-compressed file.

7.3 Nested Compression Layers

Decompression revealed successive layers: bzip2 output was identified as gzip data; gzip decompression produced another bzip2 stream; the final bzip2 output was recognised as a POSIX tar archive containing `password.txt`. The extracted credential is omitted from this report.

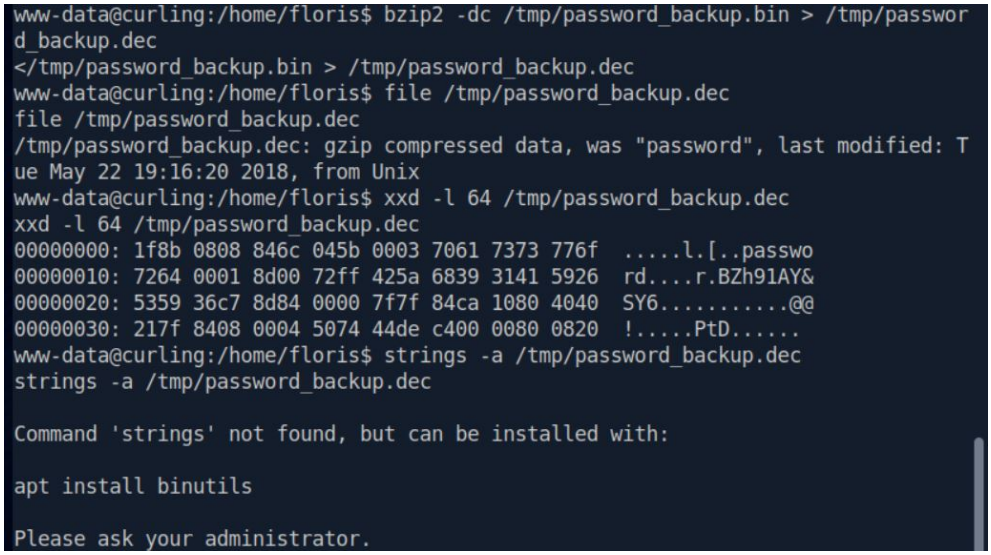


Figure 19. file identifies the first decompressed layer as gzip-compressed data.



Figure 20. The final tar archive contains password.txt.

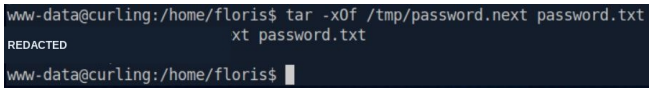


Figure 21. Extracted password value is redacted.

8 SSH Access as floris

The recovered credential was accepted by the SSH service for the local account floris. The SSH login banner confirmed Ubuntu 18.04.5 LTS and kernel 4.15.0-156-generic. Subsequent identity checks returned user `floris`, UID 1000, GID 1004, and home directory `/home/floris`.

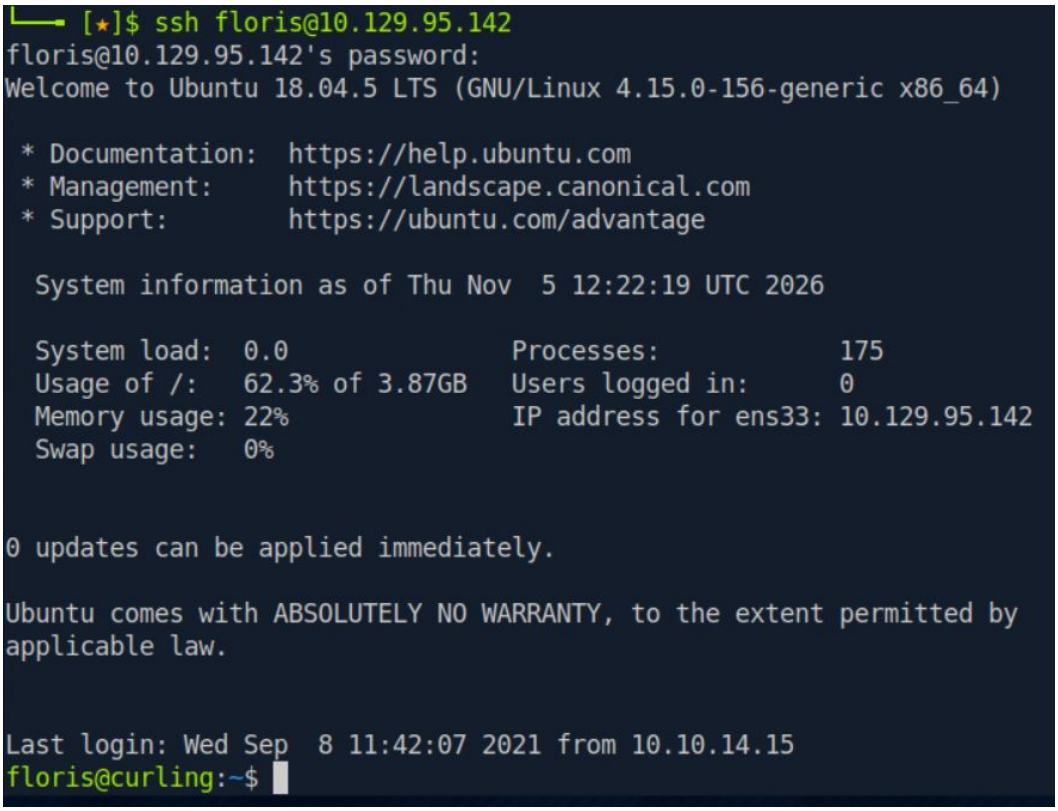


Figure 22. SSH authentication to 10.129.95.142 succeeds as floris.

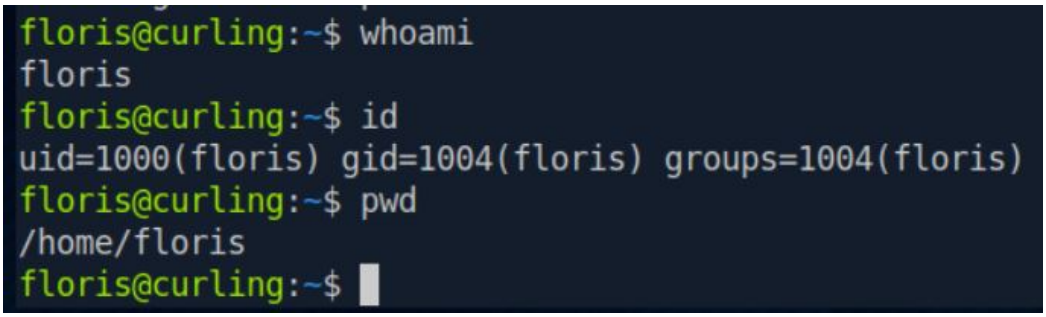


Figure 23. whoami, id, and pwd confirm the floris account and home directory.

8.1 User Flag

The user flag was read from `/home/floris/user.txt`. The value is omitted from the portfolio copy.

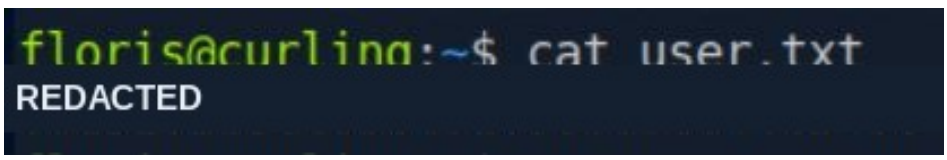


Figure 24. Successful user.txt read; the flag value is redacted.

9 Local Enumeration and Root Cron Discovery

Initial sudo enumeration showed that floris was not permitted to run sudo commands. Local review then focused on scheduled tasks, the admin-area files, process activity, and the permissions of files used by root-owned processes.

```
floris@curling:~/admin-area$ sudo -l
[sudo] password for floris:
Sorry, user floris may not run sudo on curling.
```

Figure 25. Before the cron exploit, floris is not listed as a sudo user.

```
floris@curling:~/admin-area$ ls -la
total 28
drwxr-x--- 2 root   floris  4096 Aug  2  2022 .
drwxr-xr-x 6 floris floris  4096 Aug  2  2022 ..
-rw-rw---- 1 root   floris    25 Nov  5 15:20 input
-rw-rw---- 1 root   floris 14236 Nov  5 15:20 report
```

Figure 26. admin-area contains root-owned input and report files with group floris write permissions.

9.1 Process Monitoring with pspy

pspy observed two root-owned scheduled commands. One executes `curl -K /home/floris/admin-area/input -o /home/floris/admin-area/report`. The other executes `sleep 1; cat /root/default.txt > /home/floris/admin-area/input`. The commands run on a recurring cron schedule. The input file itself is owned by root with group floris and mode 0660, so the floris group can modify its contents.

```
2026/11/05 16:14:02 CMD: UID=0     PID=2836   | cat /root/default.txt
2026/11/05 16:14:02 FS:                 OPEN | /usr/lib/locale/locale-archive
2026/11/05 16:14:02 FS:        CLOSE_NOWRITE | /usr/lib/locale/locale-archive
2026/11/05 16:15:01 FS:                 OPEN | /usr/lib/locale/locale-archive
2026/11/05 16:15:01 CMD: UID=0     PID=2841   | /bin/sh -c curl -K /home/floris/admin-area/input -o /home/floris/admin-area/report
2026/11/05 16:15:01 CMD: UID=0     PID=2840   | sleep 1
2026/11/05 16:15:01 CMD: UID=0     PID=2839   | /bin/sh -c sleep 1; cat /root/default.txt > /home/floris/admin-area/input
2026/11/05 16:15:01 CMD: UID=0     PID=2838   | /usr/sbin/CRON -f
2026/11/05 16:15:01 CMD: UID=0     PID=2837   | /usr/sbin/CRON -f
2026/11/05 16:15:01 FS:                 OPEN | /usr/bin/curl
2026/11/05 16:15:01 FS:               ACCESS | /usr/bin/curl
2026/11/05 16:15:01 CMD: UID=0     PID=2842   | curl -K /home/floris/admin-area/input -o /home/floris/admin-area/report
2026/11/05 16:15:01 FS:               ACCESS | /usr/bin/curl
```

Figure 27. pspy records root executing curl with -K against the Floris-controlled input file and a second job copying /root/default.txt into input.

The combination of a privileged curl process, a user-controlled configuration file, and the curl configuration option parser created the privilege-escalation path.

10 Privilege Escalation via curl Configuration Injection

The cron job used curl's `-K` option to load configuration directives from `/home/floris/admin-area/input`. Because floris could write this file through group permissions, its contents could be replaced before the root-owned scheduled command consumed them.

10.1 Original and Modified Configuration

The original input contained a URL directive pointing to the local host. It was replaced with a local-file URL referencing a prepared sudoers file, together with an output path targeting `/etc/sudoers`. The root cron process then executed curl with the attacker-controlled configuration.



Figure 28. Original curl configuration in input.

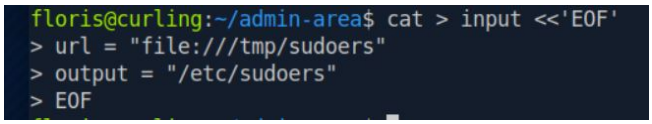


Figure 29. Modified curl configuration redirects a local-file read to /etc/sudoers.

```
url = "file:///tmp/sudoers"
output = "/etc/sudoers"
```

10.2 Root-Owned Scheduled Execution

The exploit relied on the cron process running as UID 0 and trusting a configuration file writable by a lower-privileged account. The file URL allowed curl to read the prepared local file, while the output directive caused the output to be written to the privileged sudoers path.

The second cron job also rewrote the input file after a short delay. This introduced a timing constraint, but the observed process execution and subsequent sudoers change confirmed that the modified configuration was processed.

10.3 Sudoers Modification and Root Access

The new sudoers file granted the floris account full sudo privileges. After the scheduled curl execution, `sudo -l` listed `(ALL : ALL) ALL`; running `sudo -i` opened a root shell. This verified successful privilege escalation to UID 0.

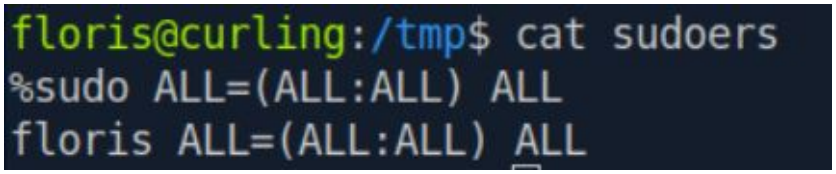


Figure 30. The resulting sudoers configuration includes a full sudo rule for floris.

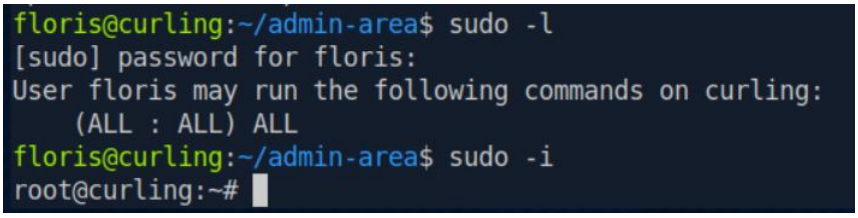


Figure 31. sudo -l confirms unrestricted sudo permissions and sudo -i opens a root shell.

10.4 Root Flag

The root flag was read after obtaining UID 0. The flag value is redacted in this portfolio copy.

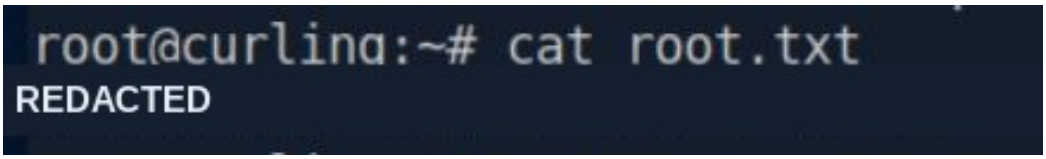


Figure 32. Successful root.txt read; the flag value is redacted.

11 Attack Chain Summary

Stage	Result
1. Reconnaissance	SSH/22 and HTTP/80 discovered; Joomla 3.8.8 fingerprinted.
2. Credential discovery	Hidden secret.txt reference identified in article HTML; Base64 credential recovered.
3. Initial access	Joomla administrator access obtained; PHP executed through the Protostar template.
4. User access	Nested password_backup archive extracted; SSH access obtained as floris.
5. Root escalation	Root cron curl config injection overwrote sudoers; unrestricted sudo led to root.

12 Findings and Risk Assessment

Finding 1 — Publicly Accessible Credential Material

Attribute	Assessment
Severity	High (indicative)
Affected component	Joomla article source and public /secret.txt resource
Evidence	Burp inspection identified an HTML comment referencing secret.txt; the endpoint returned a Base64-encoded value that decoded to a credential accepted by the administrator login.
Impact	Disclosure of an application credential enabled authenticated Joomla administrator access.
Root cause	A reusable credential was placed in a publicly accessible web resource and merely Base64-encoded.
Remediation	Remove secret material from the web root; rotate the exposed credential; store secrets in a dedicated secret manager; use strong unique credentials and MFA for administrator access.

Finding 2 — Authenticated PHP Execution Through Joomla Template Editing

Attribute	Assessment
Severity	High (indicative)
Affected component	Joomla administrator template editor; Protostar template directory
Evidence	An administrator-created probe.php under /templates/protostar/ executed when requested and reported www-data (UID 33).
Impact	Arbitrary server-side PHP execution and operating-system command execution as the web server account.
Root cause	A compromised administrator account could modify executable template files through the Joomla backend.
Remediation	Patch Joomla and extensions; restrict administrator accounts; disable production template editing where feasible; protect template files with restrictive ownership and integrity monitoring; use MFA.

12 Findings and Risk Assessment (continued)

Finding 3 — Floris Credential Recoverable from Nested Backup Archive

Attribute	Assessment
Severity	High (indicative)
Affected component	/home/floris/password_backup
Evidence	The file was accessible from the www-data context. Reconstructing the binary stream and peeling bzip2, gzip, bzip2, and tar layers exposed password.txt; its credential enabled SSH authentication as floris.
Impact	Credential disclosure enabled lateral movement from the web server account to a local SSH user.
Root cause	A sensitive credential was stored in an accessible backup archive; layered compression did not provide confidentiality.
Remediation	Remove credentials from backups; encrypt backup contents; enforce owner-only permissions; rotate the recovered password; audit home-directory and web-service access.

Finding 4 — Root Cron Job Trusts User-Writable curl Configuration

Attribute	Assessment
Severity	Critical (indicative)
Affected component	Root cron job using curl -K with /home/floris/admin-area/input
Evidence	pspy showed root executing curl with -K against input. The file was root-owned but group-writable by floris (0660). Modified curl directives redirected local-file content to /etc/sudoers.
Impact	Local privilege escalation from floris to root and full compromise of the machine.
Root cause	A privileged scheduled task consumed an attacker-controlled curl configuration file and permitted a file:// source and privileged output path.
Remediation	Do not consume user-writable config files in privileged jobs; run network retrieval with a dedicated unprivileged account; enforce allowlisted URL schemes and fixed output paths; isolate root-owned files and directories; validate input and remove write access for untrusted users.

13 Remediation Summary

Short term: Remove the exposed secret file and PHP probe; rotate the Joomla and Floris credentials; remove the vulnerable cron task or make its configuration root-controlled; restore sudoers from a trusted copy and validate its permissions.

Medium term: Upgrade the legacy Joomla, PHP, Apache, MySQL, and Ubuntu stack to supported releases; restrict template modification; review home-directory backup permissions; harden cron jobs and monitor privileged process execution.

Long term: Maintain patch management, secret-handling controls, least privilege, configuration management, file-integrity monitoring, and periodic vulnerability assessments. Retest after remediation.

14 Tools, Evidence, and Limitations

Tools evidenced in the supplied screenshots and supporting enumeration: Nmap, Nikto, Burp Suite, Firefox, Joomla administration, PHP, curl, xxd, bzip2, gzip, tar, SSH, pspy, LinPEAS (run as floris and root), and standard Linux utilities.

The screenshots and supporting LinPEAS output document the observed attack chain and final compromise in the retired training target. LinPEAS also surfaced possible kernel, SUID/Polkit, and snapd-related candidates; these were treated as unverified leads and were not used to obtain root. The assessment did not include remediation, a post-remediation retest, source-code review, or a full validation of every scanner-generated candidate.

Scanner-only observations: Nmap reported possible CSRF form exposure and a DOM-based XSS indicator; Nikto identified missing recommended HTTP security headers and an Apache version it considered outdated. These observations are not elevated to confirmed findings because no validation or exploit evidence was supplied.

Legacy platform versions were recorded during the assessment: Joomla 3.8.8, PHP 7.2.24, MySQL 5.7.35, Apache 2.4.29, Ubuntu 18.04.5, and Linux kernel 4.15.0-156-generic. Version exposure is a risk indicator; no CVE exploit against these components is claimed as part of the demonstrated attack chain.

Appendix A — Supplementary Evidence

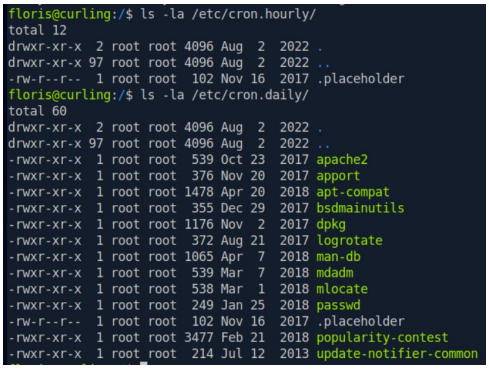


Figure A1. Additional cron directory and scheduled-task enumeration.



Figure A2. Access to the cron spool directory is denied to floris.

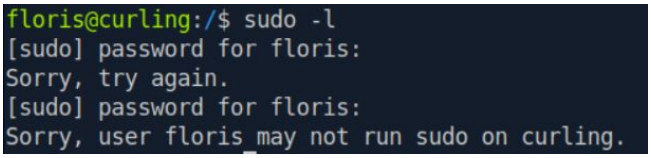


Figure A3. sudo access is denied before the cron-based escalation.

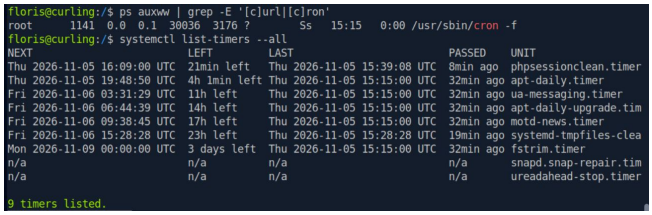


Figure A4. Systemd timer enumeration performed during local review.

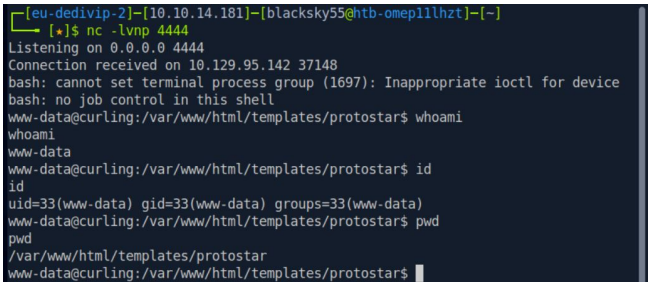


Figure A5. Additional local permission and access checks.

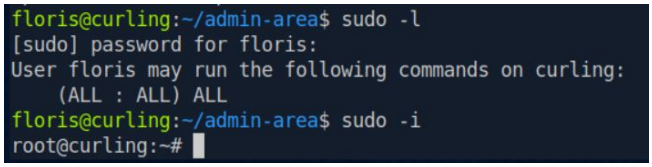


Figure A6. Root shell verification after the sudoers change.

End of Report